

Firewalls, IDS & IPS

Firewall Fundamentals

A firewall sits at a trust boundary – between the internet and your network, between zones. It decides what traffic is allowed based on policy.

Concept: default-deny beats default-allow. Whitelist what's needed.

Firewall Types

Type	Inspects	Strengths	Weaknesses
Packet filter	Headers only (L3/L4)	Fast, simple	No app awareness
Stateful	Tracks connections + headers	Blocks spoofed/unsolicited	No payload defense
NGFW	L3-L7	App awareness, TLS, IPS integrated	Expensive, slower
WAF	HTTP	Protects web apps	Targeted, not general
Host-based (HIDS)	On the server	Local visibility	Needs agent

iptables/nftables (Linux) Example

```
# Default policies: drop everything
iptables -P INPUT DROP
iptables -P FORWARD DROP
iptables -P OUTPUT ACCEPT

# Allow SSH from admin only
iptables -A INPUT -p tcp --dport 22 -s 10.0.0.50 -j ACCEPT
```

```
# Allow established/related
iptables -A INPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
```

The "established" rule is stateful – it only allows replies to connections *we* initiated.

IDS vs IPS

IDS (Intrusion Detection System) – detects, alerts, does NOT block.
(Passive; often inline tap/SPAN)

IPS (Intrusion Prevention System) – detects AND blocks inline.

Product	Type	Signature
Snort	IDS/IPS	Rule-based
Suricata	IDS/IPS	Rule-based, multi-threaded
Zeek (bro)	NSM	Event/log generator
WAF	Web-focused	Signature + behavioral

Detection Methods

Signature-based: match known patterns (fast, known threats)

Anomaly-based: baseline + flag deviations

Behavioral: detect behavior chains (e.g., suspicious process launching cmd.exe)

Signature weakness: evasion via encoding, fragmentation, polymorphism, TLS (encrypted payloads blind signature match). Modern stacks add TLS inspection and behavioral analytics.

Common Evasion Techniques (Know Your Enemy)

Fragmentation – split attack across packets so signatures don't match

Obfuscation – URL-encoding, chunked transfer

Encryption – everything inside TLS

Low-and-slow – spread attack over time to bypass thresholds

[← Wireshark & Packet Analysis](#)

Module complete ✓